

JR Clark (002035589)
NEU DAMG7350 (Spring 2026)

ASSIGNMENT: Module 1 – Cybersecurity Breach Analysis Report: National Public Data (2023-2024)

Introduction

Finding a recent cybersecurity breach for analysis is as easy as visiting <https://haveibeenpwned.com/> and plugging in any email address – current or obsolete – that you have used in the last 20-30 years. For example, I put in an email address from graduate school which has been obsolete since 1995 (jenn@convex1.tcs.tulane.edu) and came up with a 2019 data breach with verifications.io. My work email from Adobe (jenn@adobe.com) comes up in multiple breaches, including one breach of Adobe data, and other breaches long after I left the company in early 2016.

This demonstrates that organizations are holding onto information way longer than necessary, and failing to properly secure their systems, creating risk for users and a rich body of data exhaust for malicious actors.

For this report, I decided to perform my root cause analysis on the recent incident involving National Public Data (NPD), a corporation that compiles information for background checks.

Incident Overview

The National Public Data (NPD) incident is notable for the scope and sensitivity of the data involved. Estimates indicate that 2.7-2.9 billion records impacting 170 million people in the US, UK and Canada were exposed. The incident involved unauthorized access, credential exposure, and the posting of public sensitive data on both the dark web and NPD's own website.

A clear timeline of the incident helps illustrate the depth of the failure:

Timeline of Key Events (2023–2024)

- **December 2023 — Initial Unauthorized Access** A malicious actor gains unauthorized access to NPD's internal systems, accessing sensitive identity data including names, Social Security numbers, addresses, phone numbers, and relational data.
- **Late December 2023 – January 2024 — Data Exfiltration and Dark Web Posting** Stolen data is exfiltrated and begins circulating on dark web forums. NPD does not detect the intrusion during this period.
- **Early 2024 — Public Exposure of Credentials** A plaintext file containing usernames and passwords for NPD databases is discovered publicly accessible on NPD's homepage, providing direct access to sensitive systems.
- **February–March 2024 — Widespread Data Circulation** Security researchers observe the dataset spreading across multiple dark web marketplaces, indicating the breach is larger than initially understood.
- **April–May 2024 — External Discovery and Public Reporting** Journalists and cybersecurity analysts report on the breach's scale, estimating billions of exposed records. NPD still has not issued a public disclosure.

- **Mid-2024 — Legal and Regulatory Action Begins** Class-action lawsuits are filed, including *Hoffman v. National Public Data*. Regulatory bodies begin inquiries, particularly regarding GDPR's 72-hour notification requirement.
- **August 2024 — Public Acknowledgment and Broader Awareness** Court filings and investigative reporting bring the breach into mainstream visibility. NPD's delayed detection and disclosure become central issues in legal and compliance analysis.

CIA Triad Impact

The NPD data breach impacts all three components of the CIA Triad, with confidentiality suffering the most severe impact.

- **Confidentiality – critically compromised:** Highly sensitive personal information – including full names, Social Security Numbers, addresses, email, phone numbers and even names of actual/possible relatives were exposed. This represents a complete breakdown of confidentiality controls for identity-level data.
- **Integrity – potentially compromised.** While there is no evidence that stolen data was modified within NPD's systems, the exposure of such detailed identity attributes creates significant downstream integrity risks. Attackers can manipulate or combine leaked data to create synthetic identities, commit fraud or alter records in external systems that rely on NPD-sourced data.
- **Availability – indirectly affected.** The breach did not directly disrupt NPD's operational availability; however, the incident certainly eroded trust in the platform. For a data broker whose value depends on reliable, authoritative identity information, the reputational hit could be massively detrimental to their business.

Root Causes

- **Credential Exposure:** A file containing the plaintext usernames and passwords was publicly accessible on the NPD homepage. This represents a fundamental breakdown in credential management and secure configuration practices not only for the user data but for the website and many other internal processes.
- **Security Lapses:** Weak or non-existent internal access controls and lack of encryption for sensitive data enabled large-scale unauthorized access and exfiltration.
- **Delayed Detection:** The breach occurred in December 2023, but wasn't acknowledged until months later. The duration of exposure – combined with uncertainty about how long the credential file was available on the NPD homepage – indicates insufficient monitoring, logging, and incident-response capabilities.

Governance, Risk, and Compliance (GRC)

During my tenure at Abbott Labs, I managed multiple teams working on the consumer and provider marketing websites for FreeStyle Libre for the Americas. These websites did not have any ecommerce, serving only as a place to share information about the products and to offer visitors the opportunity to sign up for a mailing list or request a free product voucher (an integration with a third-party provider). No user information was stored on the website – but in the event that a web developer inadvertently made a change on the production server – that would be picked up immediately as a potential compliance issue and would be addressed as a “CAPA” (corrective and preventative action) that would require a root cause analysis (RCA)

from the IT teams and discussion about impact and prevention of future issues. (Aside: in one case, a developer from another team had merely opened a web page via Adobe Experience Manager to look at the way it was coded and when they closed, it auto-saved, showing as an update to the page).

- **Governance:** Based on the NPD lag between incident, detection and response – it appears that they lack robust data governance or breach response protocols. Risk management is a huge gap as this sort of issue would have been picked up through regular audits and monitoring of sensitive systems.
- **Risk:** As NPD deals with highly sensitive information that exposes much about individuals – their level of data security should be significantly higher than the accidental “save” of a non-PII web page by an internal web developer.
- **Compliance:** This failure indicates a total lack of compliance with any regulatory reporting requirements. Since this impacted people in the UK – clearly there are violations of compliance with GDPR, as they require 72-hour response of violations. We should probably consider likely compliance issues with CCPA and other regulations as this failure impacted users in multiple countries.

Recommendations:

This incident highlights the need for multiple layers of technical and social improvements that it’s difficult to pick just 2-3.

First, establishing a **“zero trust” architecture and enforcement of multi-factor authentication** that enforces identity verification at every access point for all users. No random vendor should have been able to publish a file to the NPD home page in the first place. Nobody should be able to access NPD systems from a non-NPD email address. This reduces risk of credential compromise, lateral movement, and unauthorized access to high-value data stores.

All workers (FTE, contract, third-party) should undergo a standardized onboarding process that includes cybersecurity training, regulatory compliance expectations, and issuance of a “Virtual Machine” or NPD-issued hardened device. This ensures consistent security baselines, eliminates unmanaged endpoints, and reduces exposure to social engineering and device-level compromise.

NPD should implement **scheduled internal and external security audits, continuous monitoring of privileged access, and automated alerting for anomalous activity**. Annual tabletop exercises and **breach-response simulations** should be conducted to validate detection, escalation, and communication workflows. This strengthens operational readiness and reduces detection and response during real incidents.

Finally, if they are not already aligned with a framework for data protection and incident response – NPD should formally adopt and operationalize a comprehensive security framework like ISO 27001 or the NIST Cybersecurity Frameworks. Alignment ensures consistent implementation of safeguards, supports regulatory compliance, and provides a defensible posture during audits or litigation.

REFERENCES:

Blade Technologies. (2024). Exploring the National Public Data breach.
<https://www.bladetechinc.com/news/exploring-the-national-public-data-breach>

Bloomberg Law. (2024). Hofmann v. Jerico Pictures, Inc. d/b/a National Public Data, No. 0:24-cv-61383 (S.D. Fla. Aug. 1, 2024).

https://www.bloomberglaw.com/public/desktop/document/HofmannvJericoPicturesIncDocketNo024cv61383SDFlaAug012024CourtDoc?doc_id=X6S27DVM6H69DSQO6MTRAQRIVBS

DocumentCloud. (2024). Hoffman v. National Public Data class action lawsuit [Court document]. <https://www.documentcloud.org/documents/25038487-hoffman-npd-class-action-lawsuit/>

Microsoft Support. (2024). National Public Data breach: What you need to know. <https://support.microsoft.com/en-us/topic/national-public-data-breach-what-you-need-to-know-843686f7-06e2-4e91-8a3f-ae30b7213535>

University of Tennessee Office of Information Technology. (2024). Understanding the National Public Data breach. <https://oit.utk.edu/security/learning-library/article-archive/understanding-the-national-public-data-breach/>

METHODOLOGY:

I created a draft of this document exceeding 900 words total, and then shared to Copilot to review before submission. CoPilot recommended addition of a timeline of events for the incident which I have added as the section entitled “Timeline of Key Events.”

- Links to the CoPilot discussion:

- <https://copilot.microsoft.com/shares/jenqh9bmMPDZLmp1f5aBC>
- <https://copilot.microsoft.com/shares/UipEcAEh9PL8JXPMXqFi8>